



Auditoria Conceitos



Auditoria de Segurança de TI

A auditoria de TI é trata-se de um processo que tem como objetivo realizar um exame minucioso e uma avaliação criteriosa sobre toda a infraestrutura de TI, incluindo todos os ativos de TI, políticas, processos, procedimentos e operações realizadas por meio do uso da TI dentro de uma organização. Podendo ainda ser compreendida como uma avaliação sistemática da segurança do sistema de informação de uma organização, por meio da medição do quão bem ele está em conformidade com um conjunto estabelecido de critérios.

Uma auditoria de segurança de TI ou uma auditoria de TI em geral busca avaliar por completo todos os mecanismos de segurança da informação e segurança cibernética aplicados em um ambiente de TI, incluindo os processos de manipulação dos ativos de TI e práticas realizadas por usuários.

As auditorias de segurança de TI são frequentemente utilizadas para determinar a conformidade perante leis, normas, regras, políticas e procedimentos adotadas pela organização ou impostos por órgãos reguladores no qual o modelo e as operações de negócio da organização estão sujeitos e, possibilitam a medição do desempenho dos mecanismos de segurança em relação a uma lista de critérios pré-estabelecidos.

Com relação ao modelo de auditoria a ser realizado, podem existir os seguintes modelos: (a) auditoria interna – no qual é realizada e conduzida por membros internos da organização, em geral a área de risco e compliance da organização fica responsável por realizar esse modelo de auditoria. Como ponto positivo deste modelo, destaca-se a rapidez em realizá-lo e o custo. Já como ponto negativo

podemos citar o fator imparcialidade. As auditorias internas são muito mais suscetíveis a terem seus resultados manipulados, menos verídicos e menos imparciais por conta de interesses internos da organização; (b) auditoria externa – no qual a organização contrata uma empresa especializada em realizar o processo de auditoria. Como ponto positivo podemos citar a veracidade e acurácia da auditoria – uma vez que neste modelo há a imparcialidade do auditor, pelo fato de este não pertencer a organização. Já como ponto negativo, destacam-se o custo para a realização da auditoria e o tempo de realização dela.

Há vários motivos pelos quais uma organização deve fazer uma auditoria de segurança da TI ou na própria TI como um todo, dos quais citamos: (a) identificação de problemas e lacunas relacionadas à segurança da informação e segurança cibernética; (b) identificação de pontos fracos (vulnerabilidades) nos ativos de TI; (c) conformidade com leis e órgãos reguladores; (d) cumprimento de políticas internas da organização; (e) identificação de recursos desnecessários ou em desuso por parte da TI, dentre outros.

Já com relação a periodicidade de uma auditoria de segurança de TI ou da própria TI, dependerá dos objetivos e metas operacionais e estratégias que a organização busca alcançar, bem como as demandas que o modelo de negócio e órgãos reguladores exigem da organização. No entanto, as auditorias em geral são realizadas em intervalos do tipo: (a) trimestral; (b) semestral ou (c) anual. Porém é importante ressaltar que sempre após uma violação de segurança ou um incidente de segurança ou na inserção de novos mecanismos de proteção a organização deve realizar uma auditoria em caráter “especial” para mensurar, verificar e avaliar os mecanismos, visando uma nova conformidade e melhoria contínua.

Com relação aos ativos a serem auditados, o ambiente de TI poderá ser examinado quanto a vulnerabilidades nas seguintes áreas: (a) rede de computadores; (b) controles e políticas de segurança; (c) proteção e privacidade de dados e dados pessoais; (d) sistemas de softwares; (e) recursos de gerenciamento de arquiteturas;

(f) controles de telecomunicação; (g) desenvolvimento de sistemas/aplicativos e, por fim (h) processo e tratamento de dados e informações;

A pessoa responsável por realizar e conduzir uma auditoria é denominado de auditor. Ele por sua vez terá como papel e responsabilidades: (a) identificar as fontes que poderão gerar as não conformidades; (b) verificar o relacionamento entre as medidas adotadas para a proteção dos ativos de TI em relação às políticas, normas e procedimentos internos da organização; © mensurar a eficiência e eficácia dos mecanismos de proteção; (d) verificar os processos e procedimentos relacionados ao tratamento de dados e informações e realizados pelas áreas de negócios e colaboradores; (e) evidenciar de forma clara e concreta as não conformidades encontradas; (f) sugerir correções de conformidade de acordo com as regras, normas, leis, regulamentações e frameworks de melhores práticas; (g) informar a alta administração da organização por meio de relatórios de auditoria todas as não conformidades encontradas durante o processo de exame e avaliação;

Conforme observa-se o processo de auditoria de TI ou auditoria de segurança de TI é de suma importância para qualquer tipo ou modelo de organização. Isto porque, além de apresentar de forma clara e transparente as vulnerabilidades encontradas nos ativos de TI e em todo ambiente de TI, incluindo os processos realizados por meio do uso da TI, resultando assim na apresentação das não conformidades, possibilita também a mensuração da eficiência e eficácia dos controles e processos realizados na TI e com a TI, além de (a) avaliar tais controles e processos, (b) determinar os riscos para os ativos de TI; © os métodos utilizados para minimizar o impacto desses riscos; (d) garantir que os processos de gerenciamento da segurança e dos ativos de TI estão em conformidade e, por fim (e) apresentar as ineficiências encontradas em todos os processos, mecanismos de proteção, técnicas, políticas, procedimentos e gerenciamentos associados a TI, o que ao final irá garantir a confidencialidade, integridade e disponibilidade da informação e de todas as operações realizadas pela TI e, que sustentam o negócio da organização.

Conteúdo Bônus

Para compreender mais sobre auditoria de sistemas de informação recomendo o seguinte artigo: O que é auditoria de sistemas e como se relaciona com a LGPD? Disponível no site Certifiquei.

Referência Bibliográfica

FONTES, E. **Praticando a segurança da informação.** – 2ªEd. Rio de Janeiro. Brasport, 2008.

HARRIS, Shon. **CISSP All-in-one, 3. ed.** Nova York, McGraw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação.** Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas.** 2.ed. São Paulo; Elsevier, 2017.

ASSI, Marcos. Governança, **Risco e Compliance: Mudando a conduta nos negócios – Edição Padrão**, São Paulo Saint Paut, 2017.

FERNANDES, Aguinaldo Aragon. ABREU, Vladimir Ferraz. **Implementando a Governança de TI: da estratégia à gestão dos processos e serviços – 4ª Ed.** Brasport – Rio de Janeiro 2014.

Ir para exercício